

Assessment Questionnaire Response:

Current Oscorp Cybersecurity Team

- Cyber Security Analyst: Generalist, responds to cyber incidents as they arise; responsible for incident detection, initial response, and reporting. Reports to Oscorp's IT Manager.
- Network Engineer: Manages firewalls and network security configurations; responsible for maintaining network integrity and monitoring. Reports to the Network Team Leader.
- Cyber Security Consultant (you): Responsible for overseeing cybersecurity strategy, risk assessments, and policy development. Initially reports to the IT Manager

Oscorp Current Cyber Security Controls

Organisational Governance

- CEO has a clear business strategy for the business. However, roles and responsibilities for cyber security haven't been defined. They're assigned to the IT team. There is no cyber security strategy.

Asset Management

- The IT team has a spreadsheet with serial numbers of laptops.
- The spreadsheet includes the model of each machine and details about the warranty.
- Oscorp uses Microsoft Office365 and relies exclusively on Software-as-a-Service applications.
- All data is in Microsoft Azure cloud.
- DevOps and Defender for Cloud are integrated services within there Microsoft Azure that support secure development and code scanning
- The IT team uses a Secure Operating Environment (SOE) to image all their laptops with the latest Windows desktop version.
- No formal asset offboarding process exists, and secure data disposal procedures are not defined

Business Continuity and Disaster Recovery

- The IT team conducts regular disaster recovery testing.
- The IT team has clear and documented business continuity plans.
- The IT team takes regular backups. Backups get tested periodically.

Vulnerability Management

- Oscorp have purchased Qualys vulnerability scanner.
- The IT team uses Qualys on an ad-hoc basis.
- There is no formal vulnerability management program in place.
- Large number of high and severe vulnerabilities reported by Qualys.

Risk Management

- Oscorp has a risk team that performs financial risk activities.
- There is no technology or cyber risk process at Oscorp.

Third Party Risk Management

- Oscorp doesn't perform any third-party risk management.
- Contracts are reviewed by procurement and finance, not IT.

Identity and Access Management

- Oscorp uses Microsoft Active Directory to manage users and groups.
- There is no privileged access management solution in place.
- Admin account password is shared with a few senior members of the IT team.
- Access to resources is granted upon request.
- The organisation does not use two-factor authentication for login.
- Complex login passwords are used.
- Employees use a VPN solution to login remotely when required.

Network Security

- The organisation has Palo Alto Next Gen firewalls include built-in features for DoS and DDoS protection, plus High availability mode.

- The firewalls have been configured by the network.
- The firewalls get audited every year by the network team.
- The firewalls get regular updates.
- The IT team have up to date network diagrams. The diagrams include the cloud environment.
- There is no established control to limit network access to authorized or secure devices.
- The network is segmented using VLANs.

Physical Security

- Oscorp is a highly secure facility, with state-of-the-art CCTV cameras everywhere.
- Oscorp takes physical security very seriously. They have logging for room access and key card access track and logs entry by users.
- They do extensive vetting for all their employees.
- A formal offboarding process is implemented, ensuring user access is promptly and properly revoked
- They have 24/7 monitoring for their research labs and physical facilities.
- Biometrics are implemented and in use.

Data Security

- Oscorp doesn't have a DLP solution.
- All data resides in Microsoft Azure cloud and Microsoft Office 365.
- Key critical application is a SaaS service from Horizon Labs.
- A formal procedure for data disposal has not been established.
- Logs are kept, but regular reviews, monitoring, and retention controls are not consistently applied
- There is no established policy limiting the use of USB or other removable media.

Policy

- There is one generic IT policy in place.

- No formal information security policy.
- There are no data governance policies or information classification.

Cyber Security Detection and Response

- There is no detection or response capability.
- They lack a formal incident response plan,
- Microsoft Defender is deployed on all endpoints for threat protection.
- The IT team responds to alerts from the antivirus (Microsoft Defender).
- Formal detection mechanisms are not in place, preventing assurance of compliance with relevant rules and regulations.
- A SIEM system is not implemented, and network traffic and user activity are not monitored or compared against baseline behavior for anomalies.
- There is no established detection or response capability as Oscorp does not conduct cyber drills, penetration tests, or other effectiveness assessments
- There is no established process to classify detected events or evaluate their impact and criticality.
- Oscorp does not engage in sharing security information with external partners or industry peers.

Security Education and Awareness

- All employees are required to do an induction web training module.
- The module includes basic instructions about cyber security.